

Informe de Análisis de Seguridad

Análisis estático de código fuente

Proyecto: C:\Users\oscar\Desktop\Proyectos\análisis_código\tests\samples

Fecha: 02/08/2026 13:05

Archivos analizados: 4

Total de hallazgos: 24

Duración del escaneo: 0.1 segundos

Severidad	Cantidad
■ Crítica	14
■ Alta	10
■ Media	0
■ Baja	0

Hallazgos de Seguridad

1. [CRÍTICA] Command Injection — <font color='Color(.862745,.078431,.235294,1)'+CWE-78

Archivo: C:\Users\oscar\Desktop\Proyectos\análisis_código\tests\samples\java\Vulnerable.java:22

Confianza: Media | **Lenguaje:** java

Descripción: Posible command injection: ejecución de comandos del sistema con datos de usuario sin sanitizar:
``Runtime.getRuntime().exec(``

Código:

```
public void runCommand(String host) { Runtime.getRuntime().exec("ping -c 1 " + host); }
```

Remediación:

Evita ejecutar comandos del sistema con input de usuario. Si es inevitable, usa listas de argumentos en vez de strings (ej: ``subprocess.run(['cmd', arg])`` en vez de ``os.system('cmd {arg}')`). JS: evita ``child_process.exec()`` con input de usuario. Usa ``execFile()`` con argumentos como array. PHP: evita ``exec()``, ``system()``, ``passthru()``, ``shell_exec()`` con input de usuario. Usa ``escapeshellarg()``. Java: evita ``Runtime.exec()`` con strings concatenados.

2. [CRÍTICA] Command Injection — <font color='Color(.862745,.078431,.235294,1)'+CWE-78

Archivo: C:\Users\oscar\Desktop\Proyectos\análisis_código\tests\samples\php\vulnerable.php:20

Confianza: Media | **Lenguaje:** php

Descripción: Posible command injection: ejecución de comandos del sistema con datos de usuario sin sanitizar:
``system("ping -c 1 " . $``

Código:

```
$host = $_GET['host']; $output = system("ping -c 1 " . $host); return $output;
```

Remediación:

Evita ejecutar comandos del sistema con input de usuario. Si es inevitable, usa listas de argumentos en vez de strings (ej: ``subprocess.run(['cmd', arg])`` en vez de ``os.system('cmd {arg}')`). JS: evita ``child_process.exec()`` con input de usuario. Usa ``execFile()`` con argumentos como array. PHP: evita ``exec()``, ``system()``, ``passthru()``, ``shell_exec()`` con input de usuario. Usa ``escapeshellarg()``. Java: evita ``Runtime.exec()`` con strings concatenados.

3. [CRÍTICA] Command Injection — <font color='Color(.862745,.078431,.235294,1)'+CWE-78

Archivo: C:\Users\oscar\Desktop\Proyectos\análisis_código\tests\samples\python\vulnerable.py:26

Confianza: Media | **Lenguaje:** python

Descripción: Posible command injection: ejecución de comandos del sistema con datos de usuario sin sanitizar:
``subprocess.call("ping -c 1 " +``

Código:

```
host = request.GET.get("host") result = subprocess.call("ping -c 1 " + host, shell=True) return result
```

Remediación:

Evita ejecutar comandos del sistema con input de usuario. Si es inevitable, usa listas de argumentos en vez de strings (ej: ``subprocess.run(['cmd', arg])`` en vez de ``os.system('cmd {arg}')`). JS: evita ``child_process.exec()`` con input de usuario. Usa ``execFile()`` con argumentos como array. PHP: evita ``exec()``, ``system()``, ``passthru()``, ``shell_exec()`` con input de usuario. Usa ``escapeshellarg()``. Java: evita ``Runtime.exec()`` con strings concatenados.

4. [CRÍTICA] Hardcoded Secrets — <font color='Color(.862745,.078431,.235294,1)'+CWE-798

Archivo: C:\Users\oscar\Desktop\Proyectos\análisis_código\tests\samples\java\Vulnerable.java:7

Confianza: Media | **Lenguaje:** java

Descripción: Secreto hardcodeado detectado en el código fuente: ``API_KEY = "****REDACTED****"``

Código:

```
public class Vulnerable { private static final String API_KEY =  
"sk-1234567890abcdef1234567890abcdef"; private static final String DB_PASS = "admin123";
```

Remediación:

Nunca guardes secretos (API keys, contraseñas, tokens) en el código fuente. Usa variables de entorno (archivos .env) con librerías como python-dotenv. Usa servicios de gestión de secretos (AWS Secrets Manager, HashiCorp Vault). En CI/CD, inyecta los secretos como variables de entorno seguras. Revoca inmediatamente cualquier secreto que haya sido expuesto en el código.

5. [CRÍTICA] Hardcoded Secrets — **CWE-798**

Archivo: C:\Users\oscar\Desktop\Proyectos\análisis_código\tests\samples\js\vulnerable.js:5

Confianza: Media | **Lenguaje:** javascript

Descripción: Secreto hardcodeado detectado en el código fuente: `API\_SECRET = "\*\*\*REDACTED\*\*\*"`

Código:

```
const API_SECRET = "super-secret-token-1234567890"; const DB_CONNECTION =  
"mongodb://admin:password123@localhost:27017/mydb";
```

Remediación:

Nunca guardes secretos (API keys, contraseñas, tokens) en el código fuente. Usa variables de entorno (archivos .env) con librerías como python-dotenv. Usa servicios de gestión de secretos (AWS Secrets Manager, HashiCorp Vault). En CI/CD, inyecta los secretos como variables de entorno seguras. Revoca inmediatamente cualquier secreto que haya sido expuesto en el código.

6. [CRÍTICA] Hardcoded Secrets — **CWE-798**

Archivo: C:\Users\oscar\Desktop\Proyectos\análisis_código\tests\samples\php\vulnerable.php:3

Confianza: Media | **Lenguaje:** php

Descripción: Secreto hardcodeado detectado en el código fuente: `API\_KEY = "\*\*\*REDACTED\*\*\*"`

Código:

```
$API_KEY = "sk-1234567890abcdef1234567890abcdef"; $DB_PASSWORD = "supersecret123";
```

Remediación:

Nunca guardes secretos (API keys, contraseñas, tokens) en el código fuente. Usa variables de entorno (archivos .env) con librerías como python-dotenv. Usa servicios de gestión de secretos (AWS Secrets Manager, HashiCorp Vault). En CI/CD, inyecta los secretos como variables de entorno seguras. Revoca inmediatamente cualquier secreto que haya sido expuesto en el código.

7. [CRÍTICA] Hardcoded Secrets — **CWE-798**

Archivo: C:\Users\oscar\Desktop\Proyectos\análisis_código\tests\samples\php\vulnerable.php:4

Confianza: Media | **Lenguaje:** php

Descripción: Secreto hardcodeado detectado en el código fuente: `PASSWORD = "\*\*\*REDACTED\*\*\*"`

Código:

```
$API_KEY = "sk-1234567890abcdef1234567890abcdef"; $DB_PASSWORD = "supersecret123";
```

Remediación:

Nunca guardes secretos (API keys, contraseñas, tokens) en el código fuente. Usa variables de entorno (archivos .env) con librerías como python-dotenv. Usa servicios de gestión de secretos (AWS Secrets Manager, HashiCorp Vault). En CI/CD, inyecta los secretos como variables de entorno seguras. Revoca inmediatamente cualquier secreto que haya sido expuesto en el código.

8. [CRÍTICA] Hardcoded Secrets — **CWE-798**

Archivo: C:\Users\oscar\Desktop\Proyectos\análisis_código\tests\samples\python\vulnerable.py:6

Confianza: Media | **Lenguaje:** python

Descripción: Secreto hardcodeado detectado en el código fuente: `API\_KEY = "\*\*\*REDACTED\*\*\*"`

Código:

```
API_KEY = "sk-1234567890abcdef1234567890abcdef" DB_PASSWORD = "admin123"
```

Remediación:

Nunca guardes secretos (API keys, contraseñas, tokens) en el código fuente. Usa variables de entorno (archivos .env) con librerías como python-dotenv. Usa servicios de gestión de secretos (AWS Secrets Manager, HashiCorp Vault). En CI/CD, inyecta los secretos como variables de entorno seguras. Revoca inmediatamente cualquier secreto que haya sido expuesto en el código.

9. [CRÍTICA] Hardcoded Secrets — <font color='Color(.862745,.078431,.235294,1)'+CWE-798

Archivo: C:\Users\oscar\Desktop\Proyectos\análisis_código\tests\samples\python\vulnerable.py:7

Confianza: Media | **Lenguaje:** python

Descripción: Secreto hardcodeado detectado en el código fuente: `PASSWORD = "\*\*\*REDACTED\*\*\*"`

Código:

```
API_KEY = "sk-1234567890abcdef1234567890abcdef" DB_PASSWORD = "admin123"
```

Remediación:

Nunca guardes secretos (API keys, contraseñas, tokens) en el código fuente. Usa variables de entorno (archivos .env) con librerías como python-dotenv. Usa servicios de gestión de secretos (AWS Secrets Manager, HashiCorp Vault). En CI/CD, inyecta los secretos como variables de entorno seguras. Revoca inmediatamente cualquier secreto que haya sido expuesto en el código.

10. [CRÍTICA] Sql Injection — <font color='Color(.862745,.078431,.235294,1)'+CWE-89

Archivo: C:\Users\oscar\Desktop\Proyectos\análisis_código\tests\samples\java\Vulnerable.java:11

Confianza: Media | **Lenguaje:** java

Descripción: Posible SQL injection detectada: ejecución de consulta SQL con concatenación de variables: `SELECT \* FROM users WHERE id = "" + userId + ""`;

Código:

```
public String getUser(String userId) { String query = "SELECT * FROM users WHERE id = '" + userId + "'"; Statement stmt = connection.createStatement();
```

Remediación:

Usa consultas parametrizadas (prepared statements) en lugar de concatenar strings. Python: usa parámetros con `cursor.execute(query, params)`. JS: usa placeholders con `db.query("SELECT \* FROM users WHERE id = ?", [userId])`. PHP: usa PDO con prepared statements. Java: usa PreparedStatement en JDBC. Si debes construir queries dinámicas, sanitiza y escapa todas las entradas.

11. [CRÍTICA] Sql Injection — <font color='Color(.862745,.078431,.235294,1)'+CWE-89

Archivo: C:\Users\oscar\Desktop\Proyectos\análisis_código\tests\samples\js\vulnerable.js:10

Confianza: Media | **Lenguaje:** javascript

Descripción: Posible SQL injection detectada: ejecución de consulta SQL con concatenación de variables: `SELECT \* FROM users WHERE id = "" + userId + ""`;

Código:

```
const userId = req.query.id; const query = "SELECT * FROM users WHERE id = '" + userId + "'"; db.query(query);
```

Remediación:

Usa consultas parametrizadas (prepared statements) en lugar de concatenar strings. Python: usa parámetros con `cursor.execute(query, params)`. JS: usa placeholders con `db.query("SELECT \* FROM users WHERE id = ?", [userId])`. PHP: usa PDO con prepared statements. Java: usa PreparedStatement en JDBC. Si debes construir queries dinámicas, sanitiza y escapa todas las entradas.

12. [CRÍTICA] Sql Injection — <font color='Color(.862745,.078431,.235294,1)'+CWE-89

Archivo: C:\Users\oscar\Desktop\Proyectos\análisis_código\tests\samples\php\vulnerable.php:8

Confianza: Media | **Lenguaje:** php

Descripción: Posible SQL injection detectada: ejecución de consulta SQL con concatenación de variables: `SELECT \* FROM users WHERE id = "" . \$id . ""`;

Código:

```
$id = $_GET['id']; $query = "SELECT * FROM users WHERE id = '' . $id . ''"; $result = mysqli_query($conn, $query);
```

Remediación:

Usa consultas parametrizadas (prepared statements) en lugar de concatenar strings. Python: usa parámetros con `cursor.execute(query, params)`. JS: usa placeholders con `db.query('SELECT \* FROM users WHERE id = ?', [userId])`. PHP: usa PDO con prepared statements. Java: usa PreparedStatement en JDBC. Si debes construir queries dinámicas, sanitiza y escapa todas las entradas.

13. [CRÍTICA] Sql Injection — CWE-89

Archivo: C:\Users\oscar\Desktop\Proyectos\análisis_código\tests\samples\php\vulnerable.php:9

Confianza: Media | **Lenguaje:** php

Descripción: Posible SQL injection detectada: ejecución de consulta SQL con concatenación de variables: `mysqli\_query(\$conn, \$`

Código:

```
$query = "SELECT * FROM users WHERE id = '' . $id . ''"; $result = mysqli_query($conn, $query); return $result;
```

Remediación:

Usa consultas parametrizadas (prepared statements) en lugar de concatenar strings. Python: usa parámetros con `cursor.execute(query, params)`. JS: usa placeholders con `db.query('SELECT \* FROM users WHERE id = ?', [userId])`. PHP: usa PDO con prepared statements. Java: usa PreparedStatement en JDBC. Si debes construir queries dinámicas, sanitiza y escapa todas las entradas.

14. [CRÍTICA] Sql Injection — CWE-89

Archivo: C:\Users\oscar\Desktop\Proyectos\análisis_código\tests\samples\python\vulnerable.py:13

Confianza: Media | **Lenguaje:** python

Descripción: Posible SQL injection detectada: ejecución de consulta SQL con concatenación de variables: `SELECT \* FROM users WHERE user="" + user + "" AND pass="" + passwd + ""`

Código:

```
passwd = request.GET.get("pass") query = "SELECT * FROM users WHERE user='" + user + "' AND pass='" + passwd + "'" cursor.execute(query)
```

Remediación:

Usa consultas parametrizadas (prepared statements) en lugar de concatenar strings. Python: usa parámetros con `cursor.execute(query, params)`. JS: usa placeholders con `db.query('SELECT \* FROM users WHERE id = ?', [userId])`. PHP: usa PDO con prepared statements. Java: usa PreparedStatement en JDBC. Si debes construir queries dinámicas, sanitiza y escapa todas las entradas.

15. [ALTA] Dynamic Exec — CWE-95

Archivo: C:\Users\oscar\Desktop\Proyectos\análisis_código\tests\samples\java\Vulnerable.java:36

Confianza: Media | **Lenguaje:** java

Descripción: Ejecución dinámica de código detectada (eval/exec/Function): `eval(`

Código:

```
ScriptEngine engine = new ScriptEngineManager().getEngineByName("JavaScript"); engine.eval(code); }
```

Remediación:

Evita `eval()`, `exec()`, `Function()` con datos dinámicos. Si necesitas ejecutar código dinámico, usa sandboxing o alternativas seguras. Python: evita `eval()` y `exec()`. Si necesitas evaluar expresiones simples, usa `ast.literal\_eval()`. JS/TS: no uses `eval()` ni `new Function()`. Para parsear JSON usa `JSON.parse()`. PHP: evita `eval()`, `preg\_replace()` con modificador /e, `create\_function()`. La ejecución de código en tiempo de ejecución casi siempre se puede evitar rediseñando la lógica.

16. [ALTA] Dynamic Exec — CWE-95

Archivo: C:\Users\oscar\Desktop\Proyectos\análisis_código\tests\samples\java\Vulnerable.java:22

Confianza: Media | **Lenguaje:** java

Descripción: Ejecución dinámica de código detectada (eval/exec/Function): `exec`

Código:

```
public void runCommand(String host) { Runtime.getRuntime().exec("ping -c 1 " + host); }
```

Remediación:

Evita `eval()`, `exec()`, `Function()` con datos dinámicos. Si necesitas ejecutar código dinámico, usa sandboxing o alternativas seguras. Python: evita `eval()` y `exec()`. Si necesitas evaluar expresiones simples, usa `ast.literal\_eval()`. JS/TS: no uses `eval()` ni `new Function()`. Para parsear JSON usa `JSON.parse()`. PHP: evita `eval()`, `preg\_replace()` con modificador /e, `create\_function()`. La ejecución de código en tiempo de ejecución casi siempre se puede evitar rediseñando la lógica.

17. [ALTA] Dynamic Exec — CWE-95

Archivo: C:\Users\oscar\Desktop\Proyectos\análisis_código\tests\samples\js\vulnerable.js:24

Confianza: Media | **Lenguaje:** javascript

Descripción: Ejecución dinámica de código detectada (eval/exec/Function): `eval`

Código:

```
const code = req.query.code; eval("var user = " + code + ";"); res.json(user);
```

Remediación:

Evita `eval()`, `exec()`, `Function()` con datos dinámicos. Si necesitas ejecutar código dinámico, usa sandboxing o alternativas seguras. Python: evita `eval()` y `exec()`. Si necesitas evaluar expresiones simples, usa `ast.literal\_eval()`. JS/TS: no uses `eval()` ni `new Function()`. Para parsear JSON usa `JSON.parse()`. PHP: evita `eval()`, `preg\_replace()` con modificador /e, `create\_function()`. La ejecución de código en tiempo de ejecución casi siempre se puede evitar rediseñando la lógica.

18. [ALTA] Dynamic Exec — CWE-95

Archivo: C:\Users\oscar\Desktop\Proyectos\análisis_código\tests\samples\js\vulnerable.js:30

Confianza: Media | **Lenguaje:** javascript

Descripción: Ejecución dinámica de código detectada (eval/exec/Function): `exec`

Código:

```
const host = req.query.host; const child = require("child_process").exec("ping -c 1 " + host); });
```

Remediación:

Evita `eval()`, `exec()`, `Function()` con datos dinámicos. Si necesitas ejecutar código dinámico, usa sandboxing o alternativas seguras. Python: evita `eval()` y `exec()`. Si necesitas evaluar expresiones simples, usa `ast.literal\_eval()`. JS/TS: no uses `eval()` ni `new Function()`. Para parsear JSON usa `JSON.parse()`. PHP: evita `eval()`, `preg\_replace()` con modificador /e, `create\_function()`. La ejecución de código en tiempo de ejecución casi siempre se puede evitar rediseñando la lógica.

19. [ALTA] Dynamic Exec — CWE-95

Archivo: C:\Users\oscar\Desktop\Proyectos\análisis_código\tests\samples\php\vulnerable.php:37

Confianza: Media | **Lenguaje:** php

Descripción: Ejecución dinámica de código detectada (eval/exec/Function): `eval(`

Código:

```
$code = $_GET['code']; eval($code); }
```

Remediación:

Evita `eval()`, `exec()`, `Function()` con datos dinámicos. Si necesitas ejecutar código dinámico, usa sandboxing o alternativas seguras. Python: evita `eval()` y `exec()`. Si necesitas evaluar expresiones simples, usa `ast.literal\_eval()`. JS/TS: no uses `eval()` ni `new Function()`. Para parsear JSON usa `JSON.parse()`. PHP: evita `eval()`, `preg\_replace()` con modificador /e, `create\_function()`. La ejecución de código en tiempo de ejecución casi siempre se puede evitar rediseñando la lógica.

20. [ALTA] Insecure Deserialization — **CWE-502**

Archivo: C:\Users\oscar\Desktop\Proyectos\análisis_código\tests\samples\java\Vulnerable.java:30

Confianza: Media | **Lenguaje:** java

Descripción: Deserialización de datos no confiables detectada: `ObjectInputStream`

Código:

```
public Object restoreState(byte[] data) throws Exception { ObjectInputStream ois = new ObjectInputStream(new ByteArrayInputStream(data)); return ois.readObject(); }
```

Remediación:

No deserialices datos que provengan de fuentes no confiables (usuarios, red). Python: evita `pickle.loads()` con datos externos. Usa JSON para serialización segura. JS: ten cuidado con `JSON.parse()` cuando los datos no están validados; no uses `eval()`. PHP: evita `unserialize()` con datos de usuario. Usa JSON. Java: usa whitelists de clases con `ObjectInputStream`, o evita la deserialización de Java nativo. Prefiere formatos de datos seguros como JSON, Protocol Buffers, o MessagePack.

21. [ALTA] Insecure Deserialization — **CWE-502**

Archivo: C:\Users\oscar\Desktop\Proyectos\análisis_código\tests\samples\php\vulnerable.php:31

Confianza: Media | **Lenguaje:** php

Descripción: Deserialización de datos no confiables detectada: `unserialize(`

Código:

```
function loadUserData($data) { $user = unserialize($data); return $user; }
```

Remediación:

No deserialices datos que provengan de fuentes no confiables (usuarios, red). Python: evita `pickle.loads()` con datos externos. Usa JSON para serialización segura. JS: ten cuidado con `JSON.parse()` cuando los datos no están validados; no uses `eval()`. PHP: evita `unserialize()` con datos de usuario. Usa JSON. Java: usa whitelists de clases con `ObjectInputStream`, o evita la deserialización de Java nativo. Prefiere formatos de datos seguros como JSON, Protocol Buffers, o MessagePack.

22. [ALTA] Insecure Deserialization — **CWE-502**

Archivo: C:\Users\oscar\Desktop\Proyectos\análisis_código\tests\samples\python\vulnerable.py:32

Confianza: Media | **Lenguaje:** python

Descripción: Deserialización de datos no confiables detectada: `pickle.loads(`

Código:

```
try: return pickle.loads(data) except Exception:
```

Remediación:

No deserialices datos que provengan de fuentes no confiables (usuarios, red). Python: evita `pickle.loads()` con datos externos. Usa JSON para serialización segura. JS: ten cuidado con `JSON.parse()` cuando los datos no están validados; no uses `eval()`. PHP: evita `unserialize()` con datos de usuario. Usa JSON. Java: usa whitelists de clases con `ObjectInputStream`, o evita la deserialización de Java nativo. Prefiere formatos de datos seguros como JSON, Protocol Buffers, o MessagePack.

23. [ALTA] Xss — CWE-79

Archivo: C:\Users\oscar\Desktop\Proyectos\análisis_código\tests\samples\js\vulnerable.js:19

Confianza: Media | **Lenguaje:** javascript

Descripción: Posible XSS (Cross-Site Scripting) detectada: renderizado de contenido no sanitizado en el DOM:
`innerHTML =`

Código:

```
const html = '<div>Welcome <b>' + user + '</b></div>';  
document.getElementById("content").innerHTML = html; });
```

Remediación:

Escapa siempre el contenido antes de insertarlo en el DOM.JS: no uses `innerHTML` / `dangerouslySetInnerHTML` con datos de usuario. Usa `textContent` o sanitización con DOMPurify.React: evita `dangerouslySetInnerHTML` a menos que sanitices con DOMPurify.Python templates: usa autoescape (Django, Jinja2).PHP: usa `htmlspecialchars()` al renderizar en HTML.Valida y sanitiza cualquier input de usuario antes de mostrarlo.

24. [ALTA] Xss — CWE-79

Archivo: C:\Users\oscar\Desktop\Proyectos\análisis_código\tests\samples\js\vulnerable.js:24

Confianza: Media | **Lenguaje:** javascript

Descripción: Posible XSS (Cross-Site Scripting) detectada: renderizado de contenido no sanitizado en el DOM:
`eval("var user = " + code +`

Código:

```
const code = req.query.code; eval("var user = " + code + ";"); res.json(user);
```

Remediación:

Escapa siempre el contenido antes de insertarlo en el DOM.JS: no uses `innerHTML` / `dangerouslySetInnerHTML` con datos de usuario. Usa `textContent` o sanitización con DOMPurify.React: evita `dangerouslySetInnerHTML` a menos que sanitices con DOMPurify.Python templates: usa autoescape (Django, Jinja2).PHP: usa `htmlspecialchars()` al renderizar en HTML.Valida y sanitiza cualquier input de usuario antes de mostrarlo.